

Network Administration / System Administration

Lab 13

Student: 吳亞倫
ID: B13901011
Department: 電機工程學系

1 Solved Problem List

Score Board ★

Steps:

1. Visit `localhost:3000/#/score-board` in browser.
2. Enter the score board page and got the score.

Bully Chatbot ★

Steps:

1. After logged in by admin, visit `http://localhost:3000/#/chatbot` in browser.
2. Constantly send the message with a lot of `COUPON` to the chatbot. After lots of tries, the chatbot will reply a coupon.

Empty User Registration ★★

Steps:

1. Visit `http://localhost:3000/#/register` in browser.
2. Fill in the registration form with random email and password.
3. Open Burp to intercept the request. Change the `email` and `password` to empty string. Then forward the request.

```
20 {  
  "email": "",  
  "password": "",  
  "passwordRepeat": "",  
  "securityQuestion": {  
    "id": 3,  
    "question": "Mother's birth date? (MM/DD/YY)",  
    "createdAt": "2025-05-23T13:57:44.692Z",  
    "updatedAt": "2025-05-23T13:57:44.692Z"  
  },  
  "securityAnswer": "2000/01/01"  
}
```

Figure 1: Use Burp to intercept the request

Login Bender ★★★

Steps:

1. Visit Juice Shop product lists, and view every product's comment to find bender's email.
2. I found out that bender's email is `bender@juice-sh.op`, at "Banana Juice (1000ml)"
3. Login with bender's email and use SQL injection to bypass the password:
 - email: `bender@juice-sh.op' --`
 - password: 123456

Login Jim ★★★

Steps:

1. Using the same method as "Login Bender", I found out that Jim's email is `jim@juice-sh.op`, at "Green Smoothie".
2. Login with Jim's email and use SQL injection to bypass the password:
 - email: `jim@juice-sh.op' --`
 - password: 123456

Forged Review ★★★

Steps:

1. After logged in as jim, I visit the product list page and click one of the product to leave a review.
2. I use burp to intercept the submit request. I changed the `author` field from `jim@juice-sh.op` to `bender@juice-sh.op`.
3. After I forward the request, the task is completed.

Error Handling ★

Steps:

1. I typed `jim', 1 or 1; --` in the login email field, and create an error.

Upload Type ★★★

Steps:

1. I go to the `/ftp/quarantine` page and download the `juicy_malware_macos_64.url` file.
2. Visit the complain page.
3. Select invoice file. I have to click "view options" in MacOS finder dialog box and change the format to All Files to upload the file. After that, I upload the "juicy malware" file.

Forged Feedback ★★★

Steps:

1. I login as jim and go to the Customer Feedback page and write a feedback.
2. I use burp to intercept the request and change the `UserId` field into another number, which is not jim's user id.
3. After I forward the request, the task is completed.

Forgotten Developer Backup ★★★★★

Steps:

1. I tried to access the `http://localhost:3000/ftp/package.json.bak` file, but it was forbidden since Only .md and .pdf files are allowed to be downloaded.
2. I found the method of Poison Null Byte Injection, which I can use the url of `http://localhost:3000/ftp/package.json.bak%00.pdf` to try to access the file. But I got a 400 error.
3. I use Burp's Decoder page to encode %00 in to url-encoded format, which is `%25%30%30`.
4. I use the url of `http://localhost:3000/ftp/package.json.bak%25%30%30.pdf` to access the file.

Poison Null Byte ★★★★★

Steps:

1. I wasn't meant to solve this task. But after I solved the "Forgotten Developer Backup" task, I accidentally use the method of this task and got the score. 笑死

Web3 Sandbox ★

Steps:

1. I go to the page `http://localhost:3000/#/score-board` and then find the Web3 Sandbox.

[illegible]